

Internal Network Penetration Test

Executive Summary

Prepared by: Sentinel Ridge Security · Engagement Type: Gray-Box Internal Penetration Test · Testing Window: April 8–17, 2026

Consultants: Travis Currier, Timothy Powell, Josue Quinones · Project Manager: Noah Whalen

This document is a sanitized excerpt of the executive summary from a senior capstone engagement at Pensacola Christian College. Gulf Coast Family Dental, P.A. is a fictional client; specific environment details (IP ranges, domain names, hostnames, account names, and service principal names) have been redacted from this public version. The full unredacted report, the 100+ page IT & Cybersecurity Operations Manual, and the Disaster Recovery Plan are available on request for hiring discussions.

Engagement Overview

Sentinel Ridge Security was engaged by the client to perform a gray-box internal penetration test of a HIPAA-regulated dental practice environment and to deliver standing operational documentation. The objective was to simulate an internal threat actor — a rogue employee or an attacker who has gained an initial foothold on the internal network — and to assess the ability to escalate privileges, access protected data, and move laterally through the environment.

The tested environment included two Windows Server 2022 domain controllers, a Red Hat Enterprise Linux 10 server hosting PostgreSQL, a Wazuh 4.14.3 SIEM platform, three Windows 11 Pro domain-joined workstations, and a dedicated Zeek/RITA passive network traffic analyzer. Testing followed the Penetration Testing Execution Standard (PTES) and NIST SP 800-115. Findings are scored using CVSS v3.1 and mapped to the MITRE ATT&CK framework.

Overall Risk Rating

HIGH — Immediate Action Required

Three High-severity findings were confirmed during active testing, any of which could materially compromise the confidentiality of protected health information if exploited.

Summary of Findings

Testing identified **seven findings** — three High severity, three Medium severity, and one Low severity — with one Medium finding remediated and verified during the engagement window. Each finding below was confirmed through active testing; reproduction steps, evidence, and remediation guidance for each are documented in the full report.

ID	Finding	Severity	Business Impact
001	Kerberoasting of database service account (orphaned SPN with no operational justification)	High	Service account hash extracted offline; cracking provides direct path to PostgreSQL database containing patient records (PHI).
002	LLMNR / NBT-NS poisoning enabled domain-wide; credential interception risk confirmed	High	Attacker on internal segment can capture employee credential hashes passively; lateral movement to AD and database becomes trivial.
003	Database service port reachable from all clinical workstations on internal segment	Medium	No network-layer control restricts database access from clinical endpoints; expands attack surface for lateral movement to PHI.
004	SIEM agent disconnected on primary domain controller for 53 minutes; Kerberoasting attack went entirely undetected	High	Highest-value monitoring target produced zero alerts during attack window; no automated alerting existed for agent disconnection.
005	Active Directory password policy weaker than documented standard (14 vs 16 char min; 365 vs 60 day max)	Medium	Reduced cracking resistance for any credential hash obtained; compromised credentials remain valid up to 6× longer than policy.
006	Active Directory password policy strengthened to 24-character minimum (resolved during engagement)	Resolved	Remediation verified during testing; documented as evidence of closed-loop remediation cycle.
007	SMB signing unverifiable on two endpoints; Front Desk AD security group has no members assigned	Low	Possible NTLM relay exposure on affected endpoints; empty AD group may indicate access-control misconfiguration.

Highlighted Finding: SIEM Detection Gap (Finding 004)

During testing, the SIEM agent on the primary domain controller lost connectivity for 53 consecutive minutes. The system appeared healthy from the platform's main dashboard, but no events from this host were being recorded during the outage. A Kerberoasting attack executed during this window — the attack succeeded, the service ticket hash was extracted, and zero SIEM alerts were generated. After the agent was manually restarted, normal event flow (Event ID 4769) resumed, confirming detection capability was functional and the failure was purely in agent connectivity.

This is a class of risk easy to miss in checklist-driven assessments: the SIEM was technically deployed and “working,” but a silent agent failure rendered detection blind on the highest-value monitoring target in the environment. Identification required correlating attack timestamps against SIEM log presence, not relying on the SIEM's own self-reporting. The compensating Zeek/RITA passive network capture would have caught the attack at the network layer — a defense-in-depth design choice that proved its value during this engagement.

Prioritized Recommendations

Immediate (within 7 days)

Address the three High-severity findings. Migrate the affected service account to a Group Managed Service Account (gMSA) and remove the orphaned Service Principal Name to eliminate the Kerberoasting exposure. Disable LLMNR and NetBIOS-NS domain-wide via Group Policy. Investigate the SIEM agent disconnection root cause and configure agent-health alerting so any future disconnection is surfaced within minutes rather than hours.

Near-term (within 30 days)

Restrict the database service port to authorized administrative hosts via host-based firewall rules. Bring the Active Directory password policy into alignment with the documented 16-character minimum and 60-day maximum age via the Default Domain Policy GPO. Audit stored credentials in database client tools across all workstations.

Within 90 days

Verify SMB signing configuration on the two endpoints where status could not be confirmed during testing. Reconcile empty AD security groups — assign appropriate members or remove if no longer required. Schedule a targeted retest of all High findings within 30 days of remediation completion, and a full-scope retest no later than 12 months from the report date.

Positive Security Observations

Several controls were verified as correctly implemented and represent genuine strengths in the client's security posture:

- All domain accounts have Kerberos pre-authentication enabled — no AS-REP Roasting exposure was identified.
- The primary domain controller correctly rejects anonymous LDAP bind attempts; unauthenticated directory enumeration is not possible.
- Local administrator rights on endpoints are restricted to the built-in Administrator and Domain Admins groups only — no clinical staff accounts have local admin access, removing a common lateral movement path.
- The SIEM platform is intentionally not domain-joined, reducing its attack surface against domain-level compromise.
- A dedicated Zeek/RITA passive network traffic analyzer provides defense-in-depth visibility independent of host-based agent connectivity — a mature investment for a practice of this size that directly compensated for the agent outage in Finding 004.

The findings documented in this report represent opportunities to strengthen an environment that already demonstrates meaningful security investment. None of the identified findings indicate a fundamental failure of the security program; they are the expected output of a thorough adversarial assessment.

This summary represents a high-level view of findings. Complete technical detail, evidence, reproduction steps, and remediation guidance for each finding are provided in the body of the full report.

Full unredacted deliverables — the complete Internal Network Penetration Test Report, the IT & Cybersecurity Operations Manual (100+ pages), and the Disaster Recovery Plan — are available on request for hiring discussions. Contact: Travis Currier, tcurrier1819@gmail.com.